

CCAF Control-Test Catalog

Reviewer edition | Continuous Control Assurance Framework | Version 1.3.1

Purpose. This catalog is the practitioner work program for the 20-test reference prototype. It allows a reviewer to assess the professional coherence of each risk, intended control state, automated procedure, and evidence follow-up without running the software.

Review boundaries

All tests are detective automated inspection or reperformance procedures. A reported condition begins an investigation; it does not by itself establish a control deviation, deficiency, misconduct, compliance failure, or financial loss.

Before relying on a completed test, an institution must establish that the queries, reports, filters, period, mappings, row counts, control totals, and approvals used to create each extract are complete and accurate for that procedure. File hashes preserve identity after extraction; they do not prove source completeness.

Completed means the required records and analytical preconditions were present. Not Evaluable means a stated precondition was absent; no exception rate may be interpreted as a clean result. Bracketed language is an institution-specific tailoring point.

Module 1: Privileged Access

PA-01 | Detective; automated inspection/reperformance

Risk addressed

Privileged access remained active after user termination (i.e., unauthorized continued access).

Intended control state

Privileged access is deactivated when a user's employment or service relationship is terminated in accordance with [institution access policy].

Automated procedure

Inspect all active privileged grants in the supplied extract and the related personnel status records to determine whether any terminated user retained active privileged access.

Evidence and professional follow-up

Inquire of the access administrator regarding each reported grant. Inspect termination records, approved exceptions, deprovisioning evidence, and the queries used to generate the user and grant extracts.

PA-02 | Detective; automated inspection/reperformance

Risk addressed

Privileged access was activated without recorded approval (i.e., unauthorized access provisioning).

Intended control state

Privileged access is approved by a designated authority prior to activation in accordance with [institution access policy].

Automated procedure

Inspect all active privileged grants in the supplied extract to determine whether an approver is recorded for each grant.

Evidence and professional follow-up

Inspect the authoritative access request, approval workflow, role assignment, and extract query. Determine whether a blank approver reflects missing authorization or incomplete field mapping.

PA-03 | Detective; automated inspection/reperformance

Risk addressed

A user approved the user's own access (i.e., incompatible request and approval duties).

Intended control state

Access is approved by an authorized person other than the individual receiving the access in accordance with [segregation-of-duties policy].

Automated procedure

Reperform the grantee-to-approver comparison across all active grants in the supplied extract to determine whether any user approved the user's own access.

Evidence and professional follow-up

Inspect user-identifier mappings, delegated-approval records, service-account treatment, and approved exceptions.

PA-04 | Detective; automated inspection/reperformance**Risk addressed**

Privileged access remained available without recent authorized use (i.e., dormant elevated access).

Intended control state

Privileged accounts are used for an authorized business purpose and are reviewed or deactivated after [institution-approved dormancy period].

Automated procedure

Inspect successful authentication activity for all active privileged users to determine whether any user had no successful authentication within the approved dormancy period. The extract must cover that period; otherwise the test is Not Evaluable.

Evidence and professional follow-up

Inspect authentication-query parameters, extract coverage, alternate authentication paths, standby-account approvals, and current business need. Failed authentications do not reset dormancy.

PA-05 | Detective; automated inspection/reperformance**Risk addressed**

Incompatible entitlements were assigned to one user (i.e., segregation-of-duties conflict).

Intended control state

Incompatible entitlements are prevented or supported by an approved compensating control in accordance with [institution conflict matrix].

Automated procedure

Reperform the configured conflict comparison across users with active grants to determine whether any user holds both entitlements in an incompatible pair.

Evidence and professional follow-up

Inspect the approved conflict matrix, role design, compensating-control evidence, and approved exceptions. Replace the demonstration conflict pairs with institution-approved combinations.

PA-06 | Detective; automated inspection/reperformance**Risk addressed**

Unusual after-hours privileged activity was not identified for review (i.e., elevated activity outside expected operating periods).

Intended control state

After-hours privileged activity is monitored and investigated in accordance with [institution monitoring standard, timezone, and maintenance calendar].

Automated procedure

Inspect successful authentication events for active privileged users during the configured activity window and compare after-hours counts across the supplied population to determine whether any user exceeds the approved peer-comparison threshold.

Evidence and professional follow-up

Inspect timezone settings, event-query logic, role and peer-group design, maintenance windows, and investigation records. The test is Not Evaluable below [minimum comparison population] or when the population has no usable variation.

PA-07 | Detective; automated inspection/reperformance**Risk addressed**

Temporary privileged access remained active beyond its approved expiry (i.e., unapproved continued access).

Intended control state

Temporary privileged access is deactivated at or before its approved expiry date, allowing only the [institution-approved grace period].

Automated procedure

Reperform the expiry check across all active temporary privileged grants in the supplied extract to determine whether any grant remained active after its approved expiry, allowing the institution-approved grace period.

Evidence and professional follow-up

Inquire of the access administrator regarding each reported grant. Inspect the approval, expiry, extension, emergency-access, and deprovisioning records to determine whether continued access was authorized.

Module 2: Change Management and Logging**CM-01 | Detective; automated inspection/reperformance****Risk addressed**

Changes to production systems were inappropriate (i.e., unapproved or not supported by recorded approval).

Intended control state

Changes to production systems are approved by the designated business or IT authority prior to implementation into the production environment, except as permitted by [emergency-change policy].

Automated procedure

Inspect all implemented change records in the supplied extract to determine whether the approver and approval timestamp are recorded.

Evidence and professional follow-up

Inspect the authoritative workflow, approval record, emergency classification, implementation timestamp, and query used to generate the change extract.

CM-02 | Detective; automated inspection/reperformance**Risk addressed**

A change was approved and implemented by the same person (i.e., incompatible change-management duties).

Intended control state

Change approval and production implementation are performed by separate authorized individuals in accordance with [institution change policy].

Automated procedure

Reperform the approver-to-implementer comparison across all implemented change records to determine whether the same identifier performed both duties.

Evidence and professional follow-up

Inspect role mappings, deployment-service accounts, delegated approvals, emergency exceptions, and workflow configuration.

CM-03 | Detective; automated inspection/reperformance**Risk addressed**

Emergency changes were implemented without timely post-implementation review.

Intended control state

Emergency changes are reviewed after implementation within [institution-approved review period] and are formally closed by an authorized reviewer.

Automated procedure

Inspect all emergency change records in the supplied extract to determine whether post-implementation review is recorded.

Evidence and professional follow-up

Inspect review evidence, review date, reviewer authority, closure records, and outstanding remediation.

CM-04 | Detective; automated inspection/reperformance**Risk addressed**

Production deployments were not supported by a valid change record (i.e., untraceable or unauthorized deployment).

Intended control state

Each production deployment is linked to a valid change record in accordance with [institution release-management policy].

Automated procedure

Inspect all deployment events in the supplied extract and reperform the match to the supplied change population to determine whether any deployment lacks a valid change reference.

Evidence and professional follow-up

Inspect deployment logs, release identifiers, bundled-deployment records, emergency procedures, and the queries used to generate both extracts.

CM-05 | Detective; automated inspection/reperformance**Risk addressed**

Required log sources stopped reporting without timely identification.

Intended control state

Required log sources transmit events within the [institution-approved heartbeat interval], and interruptions are investigated.

Automated procedure

Inspect the most recent event time for each configured log source to determine whether any source exceeded the approved heartbeat interval as of the analysis time.

Evidence and professional follow-up

Inspect the approved source inventory, expected cadence, collection-platform records, maintenance windows, clock synchronization, and incident tickets.

CM-06 | Detective; automated inspection/reperformance**Risk addressed**

The rate of emergency changes increased without investigation (i.e., deterioration in normal change practices).

Intended control state

Emergency-change rates are monitored against an approved historical baseline, and material increases are investigated.

Automated procedure

Reperform the recent-to-baseline emergency-change rate comparison over the supplied change population to determine whether the configured increase threshold is met.

Evidence and professional follow-up

Inspect period definitions, change classifications, release events, outage records, baseline comparability, and investigation evidence. The test is Not Evaluable unless [minimum recent count], [minimum baseline count], and a nonzero baseline emergency count are present.

CM-07 | Detective; automated inspection/reperformance**Risk addressed**

Production changes were implemented without recorded preproduction testing or test approval.

Intended control state

Changes are tested and approved in [institution-approved test environment] prior to implementation into the production environment, except as permitted by [emergency-change policy].

Automated procedure

Inspect all implemented change records in the supplied extract to determine whether testing is recorded as complete and a test approver is identified.

Evidence and professional follow-up

Inspect test results, evidence of review, test-environment details, production-parity considerations, emergency exceptions, and deployment authorization.

Module 3: Reconciliation and Payments**TR-01 | Detective; automated inspection/reperformance****Risk addressed**

Ledger transactions were not supported by corresponding processor-settlement records after the expected settlement period.

Intended control state

Ledger transactions are matched to processor-settlement records within the [institution-approved settlement period].

Automated procedure

Reperform the transaction-identifier match for all ledger items at or beyond the approved settlement grace period to determine whether any due item lacks a processor-settlement record.

Evidence and professional follow-up

Inspect settlement calendars, cut-off rules, rejected or reversed transactions, alternate identifiers, exception queues, and the queries used to generate both extracts.

TR-02 | Detective; automated inspection/reperformance**Risk addressed**

Ledger and processor-settlement amounts were inconsistent beyond the approved tolerance.

Intended control state

Ledger and processor-settlement amounts are reconciled within the [institution-approved amount tolerance].

Automated procedure

Reperform the amount comparison for all matched transaction identifiers to determine whether any absolute difference exceeds the approved tolerance.

Evidence and professional follow-up

Inspect currency, rounding, fees, reversals, partial settlements, product rules, and reconciliation evidence. The demonstration assumes one currency.

TR-03 | Detective; automated inspection/reperformance**Risk addressed**

Transaction identifiers were duplicated contrary to the required identifier rule.

Intended control state

Transaction identifiers are unique in accordance with [institution transaction-identification standard].

Automated procedure

Inspect all supplied ledger records and group them by transaction identifier to determine whether any identifier is associated with more than one ledger row.

Evidence and professional follow-up

Inspect the identifier design, split postings, reversals, multi-leg transactions, source-query joins, and approved exceptions.

TR-04 | Detective; automated inspection/reperformance**Risk addressed**

Unreconciled items remained open beyond the approved aging threshold.

Intended control state

Unreconciled items are investigated and resolved within [institution-approved aging period] using the applicable [business-day calendar].

Automated procedure

Reperform weekday aging for all unreconciled ledger items to determine whether any item exceeds the approved aging threshold as of the analysis date.

Evidence and professional follow-up

Inspect ownership, status accuracy, settlement and holiday calendars, cut-off, investigation records, remediation, and escalation. The demonstration counts weekdays only.

TR-05 | Detective; automated inspection/reperformance

Risk addressed

Unusual transaction velocity was not identified for review (i.e., account activity materially exceeded the comparison population).

Intended control state

Transaction velocity is monitored using [institution-approved peer groups, period, and threshold], and unusual activity is investigated.

Automated procedure

Inspect recent ledger activity by account and compare transaction counts across the supplied population to determine whether any account exceeds the approved peer-comparison threshold.

Evidence and professional follow-up

Inspect account type, seasonality, batch activity, product differences, peer-group design, query coverage, and investigation records. The test is Not Evaluable below [minimum comparison population] or when the population has no usable variation.

TR-06 | Detective; automated inspection/reperformance

Risk addressed

Transactions clustered immediately below an approval limit without investigation (i.e., threshold hovering or potential transaction splitting).

Intended control state

Activity near an approval limit is monitored using the [institution-approved amount band, period, and minimum count], and repeated patterns are investigated.

Automated procedure

Inspect ledger activity by account and count transactions within the configured band below the approval limit to determine whether any account meets the approved minimum-count threshold.

Evidence and professional follow-up

Inspect the authorization matrix, aggregation period, product context, recurring-payment patterns, account ownership, and investigation evidence.

Evidence and conclusion protocol

For every completed test, teams retain the approved configuration, source queries or reports, source-assurance record, data-quality results, evaluation status, eligible population, exception records, rule version, input hashes, reviewer disposition, and supporting records.

CCAF produces an automated exception and structures evidence for follow-up. An authorized reviewer must investigate the condition, determine whether a confirmed deviation exists, and evaluate any deficiency or finding under the institution's methodology. Those later judgments are not automated.